



School of Continuing Studies École
d'éducation permanente

Name: Ayman Al Labade

Course: CCCS 453 – Security Risk Management and

Governance Term: Winter 2026

Date: April 2nd, 2026

Desjardins Insurance Information Security Policy

Version 1.0

Effective Date: April 2nd, 2026

Prepared by: Chief Information Security Officer (CISO)

Approved by: Board of Directors

1. Introduction

This document outlines the information security policy for Desjardins Insurance. It presents the main principles, guidelines, and responsibilities used to safeguard sensitive data, manage risks, and protect the confidentiality, integrity, and availability of information assets, inspired by ISO/IEC 27001 and Canadian privacy laws.

2. Scope (Applicability of the Policy)

This information security Policy applies to:

- All employees of Desjardins Insurance (full-time, part-time, temporary, contractors, interns).
- Members of the Board of Directors and senior management.
- Third-Party service providers and partners that store, process, or access the company's information.
- All information assets (systems, applications, data, paper records) owned by or controlled by Desjardins Insurance, regardless of location (on-premises, cloud or with a supplier).

The Policy covers all business units and all Desjardins Insurance information assets, with specific emphasis on operations involving Quebec residents' personal information.

3. Objectives

The objectives of this information security policy are to:

- Protect the confidentiality, integrity, and availability of Desjardins Insurance's information assets.
- Support compliance with applicable privacy and information-security legislation and regulations, including federal and Quebec laws governing the protection of personal information.
- Align the information security program with recognized standards such as ISO/IEC 27001 and cover the main Annex A control domains (governance, people, physical, and technological control).
- Clearly define who is responsible for information security at various levels of the organization.
- Use a risk-based approach to identify, assess, and treat information security risks.
- Promote security awareness and good practices among all employees and contractors.

4. Roles Corresponding Responsibilities

4.1 Board of Directors

The Board of Directors is accountable for overseeing Desjardins information security posture and risk management related to information assets.

The Board shall:

- Approve this Policy and any material revisions.
- Reviews regular reports about key information security risks, incidents, and control status.
- Ensure information security is included in the overall enterprise risk management framework.

4.2 President/Chief Executive Officer (CEO)

The CEO is responsible for ensuring that information security is treated as a strategic priority and that sufficient resources are allocated to implement and maintain this policy.

The CEO shall:

- Send a clear message that information security is important for Desjardins Insurance's strategy and reputation.
- Appoint and support a Chief Information Security Officer (CISO) with enough authority, independence, and resources.
- Hold senior management accountable for implementation of this policy in the respective areas.

4.3 Chief Information Security Officer (CISO)

The CISO is responsible for leading the information security program and for developing, implementing, and maintaining policies, procedures, and standards based on this Policy.

The CISO shall:

- Lead the information security program and owns this policy.
- Develop and maintain information security policies, standards, and procedures aligned with ISO/IEC 27001 and applicable laws.
- Coordinate security risk assessments and risk treatment plans.
- Reports regularly to the CEO and the Board of the company's security risk, control effectiveness, and significant incidents.
- Oversee security operations, incident response, and awareness training across the company.

4.4 Senior Managers (Business and IT)

Senior executives are responsible for integrating information security requirements into their business processes, projects, and operations.

They shall:

- Ensure all local procedures and controls comply with this Policy and supporting standards.
- Allocate resources to implement risk treatment plans for information assets under their control.
- Make sure that third-party contracts under their responsibility include appropriate security and privacy requirements.

4.5 First-Line Managers (Team Leaders, Supervisors)

Managers at all levels are responsible for day-to-day enforcement of this Policy in their teams.

They shall:

- Ensure staff understand and comply with Policy and related procedures.
- Request, review, and revoke access rights for people on their team based on role and need-to-know.
- Escalate suspected or confirmed security incidents using the official incident-management process.

4.6 Employees and Contractors

Every employee and contractor has a duty to protect Desjardins insurance's assets.

All personnel shall:

- Read, understand, and comply with this Policy and any applicable standards, procedures, and guidelines.
- Complete mandatory security and privacy awareness training when joining and any role specific training assigned.
- Only access information and systems needed for their job and respect the principles of least privilege.
- Report suspicious email, strange system behavior, or data leaks as soon as they notice them.

4.7 IT Department

The information technology department is responsible for designing, implementing, and operating technical controls that support this, Policy.

IT shall:

- Implement and operate technical security controls such as secure infrastructure, networks, platforms, and applications aligned with ISO/IEC 27001 Annex A controls.
- Manage access control, implement authentication, logging, backups, and recovery mechanisms.
- Run patching, vulnerability management, and secure configuration management to keep systems up to date.

4.8 Legal and Compliance

The Legal/Compliance function is responsible for advising on applicable regulations and for monitoring compliance with the privacy and information-security obligations.

Legal/Compliance shall:

- Interpret and communicate legal and regulatory requirements, including PIPEDA and Quebec's Law 25.
- Review contracts and agreements to ensure appropriate information security and privacy clauses.
- Support regulatory reporting and interactions related to privacy or security incidents.

4.9 Internal Audit

Internal Audit provides independent assurance on the adequacy and effectiveness of information security programs.

Internal Audit shall:

- Conduct various risk-based audits of information security processes and controls.
- Verify adherence to this Policy and related standards.
- Report findings and recommendations to the Board and senior management.

5. Policy Statement – Main ISO 27001 Domains

This section provides high-level policy statements covering key ISO/IEC 27001 control domains such as information security policies, organization of information security, human resource security, asset management, access control, cryptography, physical and environmental security, operations security, communications security, system acquisition and development, supplier relationships, incident management, business continuity, and compliance.

5.1 Governance and Risk Management

- Desjardins Insurance shall maintain a documented Information Security Management System (ISMS) aligned with ISO/IEC 27001 principles, including risk assessment and risk treatment activities.
- Information security risks must be identified, analyzed (likelihood and impact), and documented using a consistent method.
- Risk treatment decisions shall be documented, approved by risk owners, and reviewed at least annually or after major changes.

5.2 Human Resource Security

- Security and privacy requirements shall be included in job descriptions, employment contracts, and onboarding process where appropriate.
- Background checks shall be performed in accordance with legal and regulatory requirements, proportional to the sensitivity of the role.
- All staff complete basic security and privacy awareness training on hire and at least annually, with extra training for high-risk roles.
- Upon termination or role change, access privileges shall be revoked or adjusted promptly, and assets shall be returned.

5.3 Asset Management and Information Classification

- Valuable information assets (applications, databases, servers, network devices, and key paper files) are recorded in an inventory with identified owners.
- Information is classified (for example Public, Internal, Confidential, Highly Confidential) based on sensitivity and potential business impact if compromised.
- Handling requirements for each classification level (storage, transmission, sharing, disposal) shall be defined and communicated.

5.4 Access Control and Identity Management

- Access to systems and data follows least-privilege and need-to-know principles to reduce unnecessary exposure.
- Strong authentication (for example multi-factor authentication) is used for removing access, privileged accounts, and other sensitive systems.
- Access should be reviewed regularly, at least quarterly for privileged accounts and at least annually for other users.
Shared accounts are avoided; if they cannot be avoided for technical reasons, they are tightly controlled and fully logged.

5.5 Cryptography

- Approved cryptography controls shall be used to protect the confidentiality and integrity of sensitive information in transit and at rest, in accordance with industries' best practices and regulatory expectations.
- Cryptographic keys shall be generated, stored, rotated, and revoked using standardized key management procedures.
- Only approved algorithms, key lengths, and protocols may be used; deprecated or insecure algorithms are prohibited.

5.6 Physical and Environmental Security

- Critical areas like data centers and network rooms have physical security such as badge access, visitor logs, and CCTV to reduce unauthorized access.
- Work areas shall be secured to prevent unauthorized viewing or access to confidential information (e.g., clean-desk policy, locked cabinets).
- Equipment shall be protected against environmental threats (for example fire, flooding, power failure) using appropriate safeguards.

5.7 Operations Security and Logging

- Operational procedures (backups, change management, scheduling, monitoring) are all documented and followed consistently.
- Security-Level events are logged, protected from tampering, and key for an appropriate amount of time for investigation and legal needs.
- Logs shall be regularly reviewed using automated or manual processes to detect anomalies and potential incidents.
- Any changes to production systems must follow a formal change management process that includes risk assessment, testing, approvals, and rollback plans.

5.8 Communications and Network Security

- Network segments are designed with defense-in-depth (for example separating inter-facing, DMZ, and internal networks).
- Secure protocols are used when sending data over untrusted networks such as the internet.
- Network security devices (firewalls, IDS/IPS, VPN gateways) are configured securely, monitored, and kept up to date.

5.9 System Acquisition, Development, and Maintenance

- Security and privacy requirements are considered from the start for a new system and major changes (“security by design” and “privacy by design”).
- Development follows secure-coding guidelines, and applications are vulnerability-tested before going live on a regular basis.
- Third-party and open-source components are monitored for known vulnerabilities and patched or mitigated within defined timelines.

5.10 Supplier and Third-Part Relationships

- Suppliers that process personal or confidential information for Desjardins Insurance are assessed for security and privacy risk before being onboarded.
- Several contracts include required information-security and privacy clauses, such as safeguards, breach notification timeframes, and secure data return or destruction.
- Supplier security performance is reviewed according to their risk level.

5.11 Information Security Incident Management

- Desjardins Insurance must maintain an incident response process that defines how to test, report, assess, contain, and recover from incidents.
- All employees and contractors must report suspected incidents (for example phishing, lost or stolen devices, unusual system behavior) through defined channels.
- All incidents involving personal information are evaluated for notification requirements under PIPEDA and provincial laws such as Quebec Law 25.

5.12 Business Continuity and Disaster Recovery

- Business impact analysis is used to identify critical processes and support systems that Desjardins Insurance depends on.

- Business continuity and disaster-recovery plans are documented, evaluated, and updated after changes or major incidents.
- Back up procedures make sure critical data can be restored within acceptable recovery time and recovery point objectives.

5.13 Compliance

- Compliance with this Policy and other security requirements is monitored using controls, management reviews, and internal or external audits.
- Non-compliance is documented, risked-assessed, and remediated in defined time frames, write follow-up by management.
- Repetition of serious violations or internal non-compliance may lead to disciplinary actions, including termination, contract cancellation, or legal steps.

6. Applicable Laws and Regulations (Related to Information Security)

- PIPEDA (Personal Information Protection and Electronic Documents Act): Federal -private sector privacy law that defines rules for collecting, using, and disclosing personal information in commercial activities, based on ten fair-information principles such as accountability, consent, limiting collection, safeguards, openness, and individual access.
- Law 25 (Bill 64) was modernized within the Quebec's private sector: strengthening privacy protections in Quebec, including privacy impact assessments, stronger consent rules, new individual rights, and mandatory breach notification.

Desjardins Insurance monitors changes in these and other relevant laws and updates its policies and controls when necessary to stay compliant and protect customers' data.

7. Compliance with the Policy (Verification Requirements)

- Managers are responsible for verifying that their teams respect this policy, for example through spot checks, access-review exercises, and process reviews.
- Internal Audit and/or Compliance may perform independent reviews and audits to verify that the policy and related procedures are being followed.
Results of these checks are documented, communicated to management, and used to improve controls, process, and training.

8. Update, Revision, and Approval of the policy

- This Policy shall be reviewed at least annually, or more frequently in response to significant changes in regulatory requirements, business operations, threat landscape, or major incidents.
- The CISO coordinated the review, with input from IT, Legal, HR and business units.
- The Board of Directors (or a delegated governance committee) must approve any significant updates.
- Approved updated versions are communicated to all relevant stakeholders, and training or awareness activities shall be upgraded if necessary.

9. Glossary (Sample Terms)

- **Information Asset:** Any data, system, application, or service that has value for Desjardins Insurance must be protected.
- **Personal Information:** Information about an identifiable individual, as defined by privacy laws such as PIPEDA and Quebec Law 25.

- **Sensitive Personal Information:** Personal Information that, due to its nature of context (e.g., financial data, health data, government identifiers), requires a higher level of protection.
- **Confidential Information:** Information that is not public and whose unauthorized disclosure could harm Desjardins Insurance, its customers, or partners.
- **Incident:** A suspected or confirmed event that compromises, or has the potential to compromise, the confidentiality, integrity, or availability of information or systems.
- **ISMS:** (Information Security Management System): A structured approach for managing information security risks, usually based on standards like ISO/IEC 270001 and including policies, process, and controls.

10. Version Control

Version	Date	Description	Author	Approver
1.0	2026-04-02	Initial release of Information Security Policy	Ayman Al Labade (CISO)	Board of Directors